

Web Attack Risk Prediction

Makine Öğrenmesi ve Açıklanabilir Yapay Zeka ile
Web Saldırı Tespiti ve KVKK Bazlı Maliyet/Fayda Analizi

YÖNETİCİ ÖZETİ RAPORU

1. Problem Tanımı

Web uygulamalarına yönelik siber saldırılar (SQL Injection, XSS, Path Traversal vb.) işletmeler için ciddi finansal ve yasal riskler oluşturmaktadır. Türkiye'de KVKK (6698 sayılı Kanun) kapsamında veri güvenliği ihlalleri 2025 yılı itibarıyla 13.620.402 TL'ye kadar idari para cezası ile sonuçlanabilmektedir.

Bu projede, bir e-ticaret web uygulamasına gelen 61.065 HTTP request analiz edilerek makine öğrenmesi tabanlı saldırı tespit sistemi geliştirilmiş, modelin işletmeye sağlayacağı finansal değer KVKK mevzuatı çerçevesinde kanıtlanmıştır.

2. Veri Kaynakları ve Harmanlama

Projede 4 farklı veri kaynağı anlamlı şekilde birleştirilmiştir:

Kaynak	Tür	Boyut	Harmanlama Rolü
CSIC 2010 HTTP	Kaggle CSV	61.065	Ana veri seti: normal ve saldırı HTTP request'leri
Web App Payloads	Kaggle JSONL	455	Saldırı imzaları + regex pattern üretimi
Foospidy Payloads	GitHub	28.569	Kapsamlı saldırı pattern koleksiyonu
Türkiye KVKK Veritabanı	Sentetik	250	KVKK cezaları + maliyet mapping

Harmanlama: Payload koleksiyonlarından (Kaynak 2+3) regex pattern'leri üretilmiş, CSIC request'leri (Kaynak 1) bu pattern'lerle eşleştirilmiş ve tespit edilen saldırı türüne göre KVKK maliyet bilgisi (Kaynak 4) merge edilmiştir.

3. Üretilen Yeni Özellikler (Feature Engineering)

HTTP request'lerden siber güvenlik domain bilgisine dayalı 12 yeni feature türetilmiştir. Data leakage önlemek için regex-based pattern flag'leri modelden çıkarılmıştır:

- request_length, url_length, content_length: Request boyut metrikleri — uzun request'ler injection payload barındırabilir
- special_char_count, digit_count: Saldırı syntax'ının temel yapı taşları
- entropy_score: Shannon entropy — yüksek entropi obfuscated payload göstergesi
- encoded_char_ratio: URL-encoded karakter oranı — WAF bypass girişimi tespiti
- uppercase_ratio: Büyük harf oranı — encoding manipülasyonu göstergesi
- parameter_count, url_depth, is_post, is_put: Yapısal HTTP özellikleri

4. Model Çalışması ve Sonuçlar

Random Forest ve XGBoost modelleri eğitilmiş, 5-fold Stratified Cross Validation ile değerlendirilmiştir:

Model	Accuracy	F1 Score	Precision	AUC-ROC
Random Forest	0.9391	0.9279	0.90	0.9912
XGBoost	0.9406	0.9287	0.91	0.9915

XGBoost modeli tüm metriklerde marginal olarak daha iyi performans göstermiş ve en iyi model olarak seçilmiştir.

5. Açıklanabilir Yapay Zeka (SHAP) Bulguları

Model kararları SHAP (SHapley Additive exPlanations) ile açıklanabilir hale getirilmiştir. SHAP analizi, her feature'ın her bir tahmin üzerindeki marjinal katkısını hesaplar.

Temel Bulgular:

- encoded_char_ratio (URL encoding oranı) en yüksek SHAP etkisine sahip — WAF bypass girişimlerini tespit ediyor
- request_length ve uppercase_ratio ikinci ve üçüncü sırada — anormal boyuttaki request'ler saldırı göstergesi
- entropy_score yüksek olduğunda saldırı olasılığı artıyor — obfuscated payload tespiti
- special_char_count ve digit_count SQL injection ve XSS belirtilerini yakalıyor

SHAP sonuçları siber güvenlik domain bilgisiyle tam tutarlıdır: model, bir güvenlik uzmanının bakacağı özelliklere odaklanmaktadır.

6. KVKK Bazlı Maliyet/Fayda Simülasyonu ve İşletme Değeri

Modelin işletme değeri, Türkiye KVKK mevzuatına dayanan finansal simülasyonla kanıtlanmıştır.

6.1 Maliyet Matrisi

Senaryo	Birim Maliyet	Gerekçe
False Positive (FP)	150 TL	Normal kullanıcı bloklandı → destek maliyeti + müşteri kaybı riski
False Negative (FN)	5.000 TL	Saldırı kaçırıldı → KVKK ceza riski + veri ihlali potansiyeli
True Positive (TP)	-500 TL	Saldırı engellendi → potansiyel zarardan tasarruf

Not: FN birim maliyeti (5.000 TL), KVKK veritabanındaki ortalama olay maliyetlerinin (8-12M TL) basitleştirilmiş halidir. Gerçek dünyada SQLi (ort. 11.86M TL) ve RCE (ort. 8.96M TL) çok daha yüksek maliyet üretir.

6.2 Threshold Optimizasyonu

Standart %50 karar eşiği yerine, maliyet fonksiyonunu minimize eden optimal threshold aranmıştır:

- Default threshold (0.50): Toplam maliyet -872.850 TL
- Optimal threshold (0.05): Toplam maliyet -2.330.650 TL
- Threshold optimizasyonu ile ek 1.457.800 TL tasarruf sağlanmıştır

Bu, standart %50 eşiğinin neden yetersiz olduğunun kanıtıdır. Düşük threshold, saldırı kaçırma riskini (ve dolayısıyla KVKK ceza riskini) minimize eder.

6.3 Senaryo Karşılaştırması ve ROI

Senaryo	Toplam Maliyet	Açıklama
Senaryo 1: Model Yok	25.065.000 TL	Tüm saldırılar kaçırılır
Senaryo 2: Default (t=0.50)	-872.850 TL	Standart eşik
Senaryo 3: ML Model (t=0.05)	-2.330.650 TL	Optimal eşik

Net Tasarruf (Model Yok vs ML Model)	27.395.650 TL
ROI (Yatırım Getirisi)	%1.175+

KVKK veritabanındaki saldırı türü bazlı ortalama maliyetler:

Saldırı Türü	Ort. KVKK Cezası	Ort. Toplam Maliyet	ML Tespit Oranı
SQL Injection	3.949.031 TL	11.860.847 TL	%43
Brute Force	3.616.885 TL	9.810.881 TL	%45
RCE	3.532.965 TL	8.958.003 TL	%38
Path Traversal	3.131.353 TL	9.249.774 TL	%41
XSS	2.660.755 TL	7.824.259 TL	%41

7. Sonuç ve Öneriler

Bu proje, web saldırı tespitinde makine öğrenmesinin sadece teknik değil, aynı zamanda finansal ve yasal bir değer üretebileceğini göstermiştir.

Yapılanlar:

- 4 farklı veri kaynağı (CSIC 2010, Kaggle Payloads, Foospidy, KVKK Veritabanı) başarıyla harmanlanmıştır
- 12 iş mantığına dayalı feature türetilmiş, data leakage önlenmiştir
- XGBoost modeli %94.06 doğruluk ve 0.9915 AUC-ROC ile saldırı tespit etmiştir
- 5-fold Cross Validation ile modelin genelleştirme kapasitesi doğrulanmıştır
- KVKK bazlı maliyet simülasyonu ile ~27.4M TL net tasarruf ve %1.175+ ROI kanıtlanmıştır
- SHAP ile model kararları şeffaf ve denetlenebilir hale getirilmiştir

Öneriler:

- Üretim ortamında threshold=0.05 ile deploy edilmesi önerilir (KVKK ceza riskini minimize eder)
- Model, WAF (Web Application Firewall) önüne ek bir katman olarak entegre edilebilir
- KVKK uyum süreçlerinde “veri güvenliği yükümlülüğü” kapsamında ML tabanlı IDS kullanımı gösterilebilir
- Modelin periyodik olarak yeni payload veritabanlarıyla güncellenmesi önerilir

YBS 4. Sınıf — Python ile Veri Bilimi Dönem Sonu Projesi

Kaynak: KVKK Madde 18 (2025 güncel tutarlar), IBM Cost of Data Breach Report 2024